MITRE ATLAS | AML.CS0020 - Indirect Prompt Injection Threats: Bing Chat Data Pirate

Entry Information

ID:
AML.CS0020

Type:
Case-Study

Name:
Indirect Prompt Injection Threats: Bing Chat Data Pirate

URL:
https://atlas.mitre.org/studies/AML.CS0020/

Incident Date:
2023-01-01

Target:
Microsoft Bing Chat

Actor:
Kai Greshake, Saarland University

Description

Whenever interacting with Microsoft's new Bing Chat LLM Chatbot, a user can allow Bing Chat permission to view and access currently open websites throughout the chat session. Researchers demonstrated the ability for an attacker to plant an injection in a website the user is visiting, which silently turns Bing Chat into a Social Engineer who seeks out and exfiltrates personal information. The user doesn't have to ask about the website or do anything except interact with Bing Chat while the website is opened in the browser in order for this attack to be executed.

In the provided demonstration, a user opened a prepared malicious website containing an indirect prompt injection attack (could also be on a social media site) in Edge. The website includes a prompt which is read by Bing and changes its behavior to access user information, which in turn can sent to an attacker.

Attack Procedure:
[AML.T0017] Develop Capabilities: The attacker created a website containing malicious system prompts for the LLM to ingest in order to influence the model's behavior. These prompts are ingested by the model when access to it is requested by the user.
[AML.T0068] LLM Prompt Obfuscation: The malicious prompts were obfuscated by setting the font size to 0, making it harder to detect by a human.
[AML.T0051.001] Indirect: Bing chat is capable of seeing currently opened websites if allowed by the user. If the user has the adversary's website open, the malicious prompt will be executed.
[AML.T0052.000] Spearphishing via Social Engineering LLM: The malicious prompt directs Bing Chat to change its conversational style to that of a pirate, and its behavior to subtly convince the user to provide PII (e.g. their name) and encourage the user to click on a link that has the user's PII encoded into the URL.
[AML.T0048.003] User Harm: With this user information, the attacker could now use the user's PII it has received for further identity-level attacks, such identity theft or fraud.

References

- Indirect Prompt Injection Threats: Bing Chat Data Pirate — https://greshake.github.io/